

Full Security & Technical Audit



Generated: October 07, 2026

Domain	sarh-company.com
Stack	Next.js 14.2.3 / Supabase / Vercel / Cloudflare R2
Scope	Mode B+C — Source code + Supabase live access
Experts	8 specialist experts (Frontend, Caching, Security, Infra, DevOps, DBA, SEO, Full-Stack)
Date	2026-10-07

Executive Summary

A comprehensive audit of **sarh-company.com** was conducted across 8 specialist domains. A total of **19 findings** were identified: **2 Critical**, **1 High**, **9 Medium**, **5 Low**. The two Critical findings require **immediate action**: an open Supabase Storage bucket that allows anonymous file upload/delete, and a Next.js version with known Cache Poisoning and DoS CVEs in production. All findings include precise remediation steps.

Severity	Count	Status
■ Critical	2	Immediate — within 24h
■ High	1	Urgent — within 1 week
■ Medium	11	Plan — within 1 month
■ Low	5	Backlog — next sprint

Findings Overview

#	Expert	Severity	Finding
1	Expert 1	Medium	PNG Icon Sprites (377 requests, 1.5MB)
2	Expert 1	Low	Missing width/height on property card images
3	Expert 2	Medium	R2 images missing Cache-Control header
4	Expert 2	Low	Property pages missing ISR revalidate
5	Expert 3	Medium	JSON-LD dangerouslySetInnerHTML without HTML escaping
6	Expert 3	Medium	Session secret derived from ADMIN_PASSWORD
7	Expert 3	Low	No security.txt
8	Expert 4	Medium	SSL certificate expires Dec 10 2026 (64 days)
9	Expert 4	Medium	No SPF/DMARC records — email spoofing possible
10	Expert 5	Critical	Next.js 14.2.3 has Cache Poisoning + DoS CVEs
11	Expert 5	Medium	In-memory rate limiting resets on cold start
12	Expert 5	Medium	Passwords hashed with SHA-256 (no salt)
13	Expert 6	Critical	Storage bucket allows anonymous upload & delete
14	Expert 6	Medium	admin_users has no explicit RLS policy
15	Expert 7	High	Homepage and /properties are 'use client' — no page-level metadata
16	Expert 7	Medium	OpenGraph image is 512x512 (square) instead of 1200x630
17	Expert 8	Medium	video_url not validated as TikTok URL before client-side embed
18	Expert 8	Low	Maintenance flag stored in inquiries table
19	Expert 8	Low	used_listing_numbers loads up to 100k rows into memory

Detailed Findings

Expert 1 — Frontend / Performance

#1 PNG Icon Sprites (377 requests, 1.5MB)

Medium

Arabic Title: 377 PNG — 1.5MB

Description: All tab/filter icons load as individual PNG files (377 requests). This delays First Contentful Paint and increases bandwidth.

Remediation: Convert icons to SVG sprite or icon font. Reduces to 1 request.

#2 Missing width/height on property card images

Low

Arabic Title: width/height — CLS

Description: Property card image tags lack explicit width/height attributes, causing layout shift (CLS) during load.

Remediation: Add width={400} height={300} (or aspect-ratio CSS) to PropertyCard image elements.

Expert 2 — Caching / CDN

#3 R2 images missing Cache-Control header

Medium

Arabic Title: R2 Cache-Control

Description: Images served from R2 public URL have no Cache-Control header. Browsers re-validate on every visit instead of serving from cache.

Remediation: Add Cache-Control: public, max-age=31536000, immutable via Cloudflare Transform Rule on *.r2.dev domain.

#4 Property pages missing ISR revalidate

Low

Arabic Title: ISR revalidate

Description: getProperty() uses cache: 'no-store' — every request hits Supabase. With ISR, cached pages serve instantly and revalidate in background.

Remediation: Add next: { revalidate: 300 } (5 min) to the Supabase fetch in getProperty().

Expert 3 — Application Security

# 5	JSON-LD dangerouslySetInnerHTML without HTML escaping	Medium
<i>Arabic Title:</i> JSON-LD escape < > Description: Property titles containing < or > characters can break JSON-LD schema and potentially confuse parsers. Remediation: Replace: <code>JSON.stringify(schema)</code> with <code>JSON.stringify(schema).replace(/</g, '\u003c').replace(/>/g, '\u003e')</code>		

# 6	Session secret derived from ADMIN_PASSWORD	Medium
<i>Arabic Title:</i> session secret derived from admin password Description: <code>signingSecret()</code> returns <code>ADMIN_PASSWORD + 'sarh_session_2026'</code>. Leaking the admin password compromises both login AND session forgery. Remediation: Add <code>SESSION_SECRET</code> env var (32 random bytes) independent from <code>ADMIN_PASSWORD</code>. Use it exclusively for cookie signing.		

# 7	No security.txt	Low
<i>Arabic Title:</i> security.txt Description: <code>/.well-known/security.txt</code> is missing. It provides a standard channel for responsible vulnerability disclosure. Remediation: Create <code>public/well-known/security.txt</code> with contact and expiry fields.		

Expert 4 — Infrastructure / TLS

# 8	SSL certificate expires Dec 10 2026 (64 days)	Medium
<i>Arabic Title:</i> SSL certificate expires 10 Dec 2026 Description: Let's Encrypt cert expires in 64 days. Vercel auto-renews, but hobby plan renewals occasionally fail silently. Remediation: Monitor via Vercel dashboard. Set a calendar reminder for Nov 20 to verify renewal occurred.		

# 9	No SPF/DMARC records — email spoofing possible	Medium
<i>Arabic Title:</i> ■■ SPF ■■■■ DMARC — ■■■■■■ ■■■■■■ ■■■■ Description: MX uses Namecheap registrar forwarding (eforward1-5). No SPF TXT record means anyone can send email as @sarh-company.com. Remediation: Add TXT record: v=spf1 include:registrar-servers.com ~all. Add DMARC: _dmarc TXT v=DMARC1; p=quarantine; rua=mailto:admin@sarh-company.com		

Expert 5 — DevOps / Dependencies

# 1 0	Next.js 14.2.3 has Cache Poisoning + DoS CVEs	Critical
<i>Arabic Title:</i> Next.js 14.2.3 — ■■■■ Cache Poisoning ■ DoS Description: next@14.2.3 has two known CVEs in production: (1) Cache Poisoning allows attackers to serve malicious cached content. (2) DoS via image optimization endpoint. Latest Next.js patches both. Remediation: Run: npm install next@latest (upgrades to Next.js 15/16). Test build after upgrade.		

# 1 1	In-memory rate limiting resets on cold start	Medium
<i>Arabic Title:</i> Rate limiting ■■ ■■■■■■■■ — ■■■■■■ ■■■■ cold start Description: loginAttempts Map lives in Serverless function memory. Each new instance starts fresh — distributed brute-force bypasses the limit. Remediation: Replace Map with Vercel KV (Redis). 3 lines of code change in middleware.ts.		

# 1 2	Passwords hashed with SHA-256 (no salt)	Medium
<i>Arabic Title:</i> ■■■■■■ ■■■■■■■■ ■■■■■■■■ ■■ SHA-256 ■■■■ salt Description: admin_users.password_hash uses raw SHA-256. Identical passwords produce identical hashes, vulnerable to rainbow table attacks. Remediation: Replace createHash('sha256') with bcrypt (cost=12) or argon2id. One-time migration of existing hashes on next login.		

Expert 6 — Database / Supabase

Expert 8 — Full-Stack Code Review

[illegible]

Previously Fixed Issues (This Session)

- OK R2 migration: all 80 properties migrated to Cloudflare R2 storage
- OK CSP headers updated with R2 domain (img-src, connect-src, media-src)
- OK SSRF fix: tiktok-thumb API now validates hostname before fetch
- OK Removed deprecated X-XSS-Protection header
- OK Duplicate page title fixed ('<title> | Sarh | Sarh' pattern eliminated)
- OK @supabase/supabase-js upgraded from 2.107.0 to ^2.117.2
- OK TypeScript strict mode fix: Buffer -> Uint8Array in R2 upload body
- OK Next.js remotePatterns updated to allow R2 domain for Image component

Prioritized Action Plan

NOW — Within 24h

- 1. Drop Supabase Storage allow_upload & allow_delete policies [Finding #13]
- 2. Upgrade Next.js: npm install next@latest, test, deploy [Finding #11]

URGENT — Within 1 Week

- 3. Add SESSION_SECRET independent env var [Finding #6]
- 4. Fix /properties page metadata (server wrapper + canonical) [Finding #15]

PLAN — Within 1 Month

- 5. Add SPF + DMARC DNS records for email spoofing protection [Finding #9]
- 6. Replace SHA-256 password hashing with bcrypt/argon2 [Finding #12]
- 7. Escape JSON-LD output (replace < > with unicode escapes) [Finding #5]
- 8. Add Cache-Control to R2 images via Cloudflare rule [Finding #3]
- 9. Move rate limiting to Redis/Vercel KV [Findings #10, #12]
- 10. Add client-side TikTok URL validation in PropertyDetail.tsx [Finding #17]
- 11. Create OG image 1200x630 [Finding #16]

BACKLOG

- 12. Add explicit admin_users RLS deny policy [Finding #14]
- 13. Add ISR revalidate to property pages [Finding #4]
- 14. Convert PNG icon sprites to SVG [Finding #1]
- 15. Move maintenance flag to site_settings table [Finding #18]
- 16. Replace 100k-row listing number query with MAX()+1 [Finding #19]
- 17. Add security.txt [Finding #7]

This report was generated by 8 specialist AI experts as part of a comprehensive security and technical audit of sarh-company.com. All findings are based on direct code review and live infrastructure analysis. No active exploitation was performed. Report date: 2026-10-07 | Prepared by: ASI Mjed Engineering Team